

Technical foundation and data model

How the site is built, how its data fits together, and why it looks the way it does. A summary of `DATA_MODEL.md` and `CLAUDE.md`, with the diagrams taken from the former.

Contents

- | | |
|---|--|
| 1. What the site is | 8. Badges and belts |
| 2. Technical foundation | 9. Volunteers: applications and background checks |
| 3. Architectural principles and their rationale | 10. Pathways, content, notifications and geography |
| 4. The data model at a glance | 11. The mail engine |
| 5. Accounts, families and roles | 12. Security |
| 6. Dojos, teams and access | 13. Privacy by design |
| 7. Sessions, registrations and attendance | 14. Languages, testing and operations |

1 What the site is

A Django site for CoderDojo Belgium: free coding clubs for children aged 7–17, run by volunteers. It replaces spreadsheets and forms with one place where families find a dojo and sign their children up, volunteers are vetted once and help at any dojo, dojo teams run their sessions, and the organisation communicates, promotes and keeps the whole thing lawful.

Who	What they do on the site
Visitors and families	Discover dojos and sessions, create a family account, sign children up (with a waiting list), follow belts and badges, manage mail, security and their data.
Ninjas	Optionally their own login, given by a guardian: see their progress, sign themselves up.
Mentors	Apply once, pass a Belgian background check, then join any dojo's team: sessions, attendance, belts and badges, the team.
Champions	Run a dojo: everything a mentor does plus its lifecycle, health notes, mail to the families and API clients.
The organisation	Reviewers (background checks, applications), admins (campaigns, segments, content, awards, privacy, people, security), the board; the Django admin only for technical fixes.

Where the knowledge lives

- `DATA_MODEL.md` : the data model, one Mermaid diagram per area, plus the design rationale and plan of every larger change (sections 10–25). The diagrams in this document are taken from it unchanged.
- `CLAUDE.md` : the conventions, the architecture and the gotchas: what a developer (human or AI) needs to change the code safely. Kept current in the same change as the code.
- `docs/` : the end-user help centre (Sphinx, English, French and Dutch).
- `user-journeys/` : one PDF per persona with screenshots, in English and Dutch.

In numbers

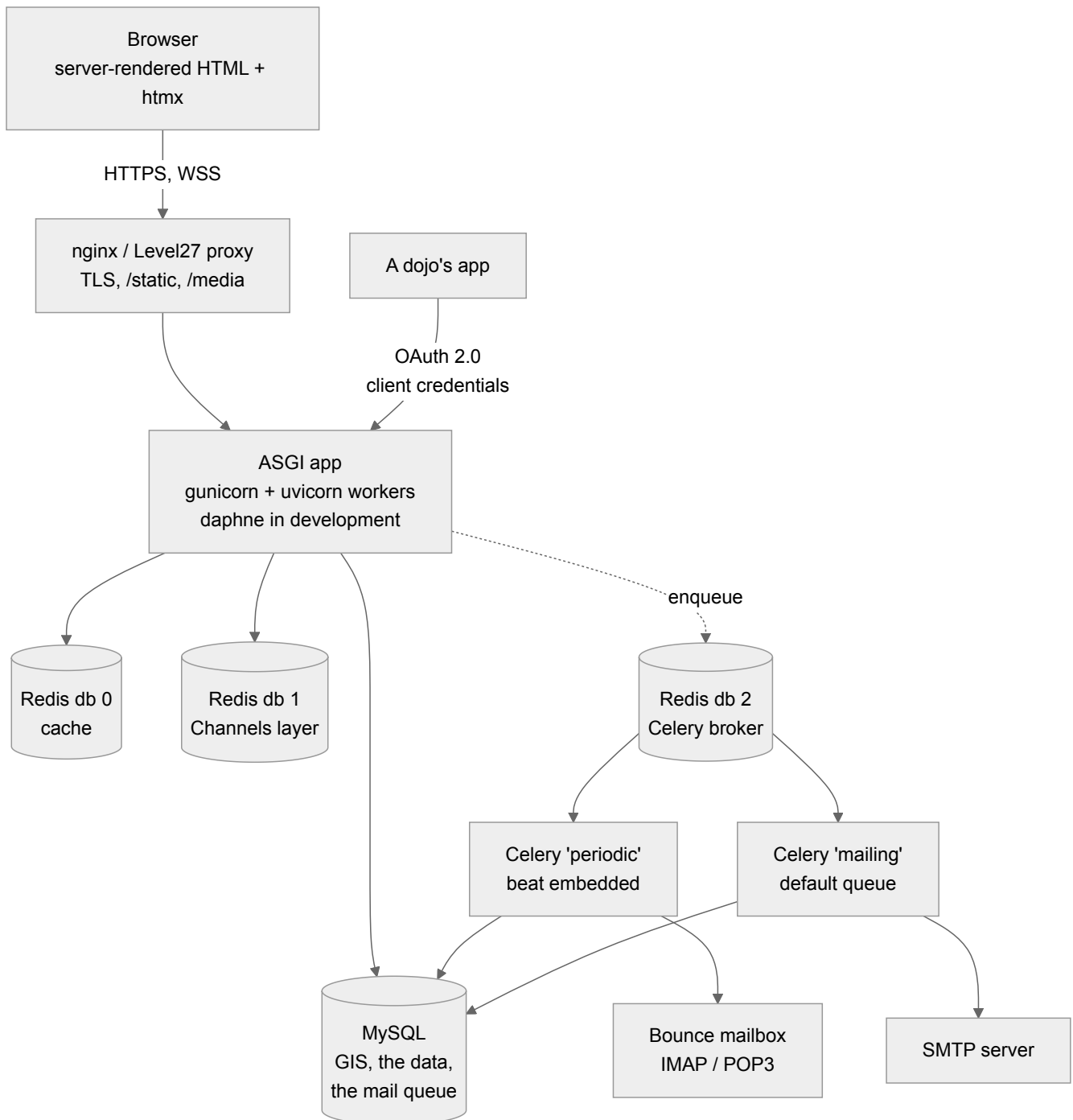
Django apps	12 of our own (plus <code>website</code> for settings)	Models	51 of our own
Test functions	about 1,000 (Django test runner)	Languages	English, Dutch, French

2 Technical foundation

The stack

Layer	Choice	Why
Language, framework	Python 3.14, Django 6.1	Batteries included (auth, admin, forms, i18n, migrations); the admin doubles as the always-working emergency tool.
Database	MySQL 9 with <code>django.contrib.gis</code>	What the hosting offers; spatial columns for dojo locations, postcodes and provinces.
Front end	Server-rendered templates + htmx 2.0, one hand-kept <code>bundle.js</code> / <code>bundle.css</code>	No build step, no SPA: the server stays the single source of truth; htmx swaps fragments for the dynamic parts.
Serving	ASGI: gunicorn with uvicorn workers in production, daphne behind <code>runserver</code> in development	WebSockets for the live notification bell, in the same process as the pages.
Real time	Django Channels over Redis (db 1)	The bell updates itself without polling.
Background work	Celery 5.6, two workers, beat embedded in one; Redis db 2 as broker	Every mail, the nightly engagement rebuild, retention and reminders run off the request.
Cache	Redis db 0 (<code>IGNORE_EXCEPTIONS</code>)	Public lists; the site keeps working if Redis hiccups.
Auth	django-two-factor-auth on django-otp, WebAuthn passkeys; login links	Optional two-step login for everyone, enforceable per role by the organisation.
API	django-ninja + django-oauth-toolkit (client credentials)	Typed endpoints with an OpenAPI spec; apps act for one dojo with scoped tokens.
Audit	django-auditlog	Who changed what, and who viewed the most sensitive data.
Hosting	Level27 Python hosting (SSH, systemd user units); a devcontainer for development	A small, affordable setup for a volunteer organisation, deployed with one script.

How the pieces connect



Runtime architecture. Only nginx is exposed; in development it also serves the docs, Mailpit, phpMyAdmin and a test authenticator under their own paths.

Environments

- **Development** is the `.devcontainer` stack: nginx with a local CA for `coolregistration.localhost` (only port 443 is published), MySQL, Redis, Mailpit catching every mail (and acting as the bounce mailbox), both Celery workers, and seeded demo data from about twenty rerun-safe seed commands. End-to-end checks go through nginx, never straight to Django, because TLS, the WebSocket upgrade and the tool paths live there.
- **Production** is deployed by `scripts/deploy.sh`: bundle the tree, install requirements into the Python env gunicorn uses, run `manage.py check` on the new code *before* touching the live app, `rsync`, migrate, reload

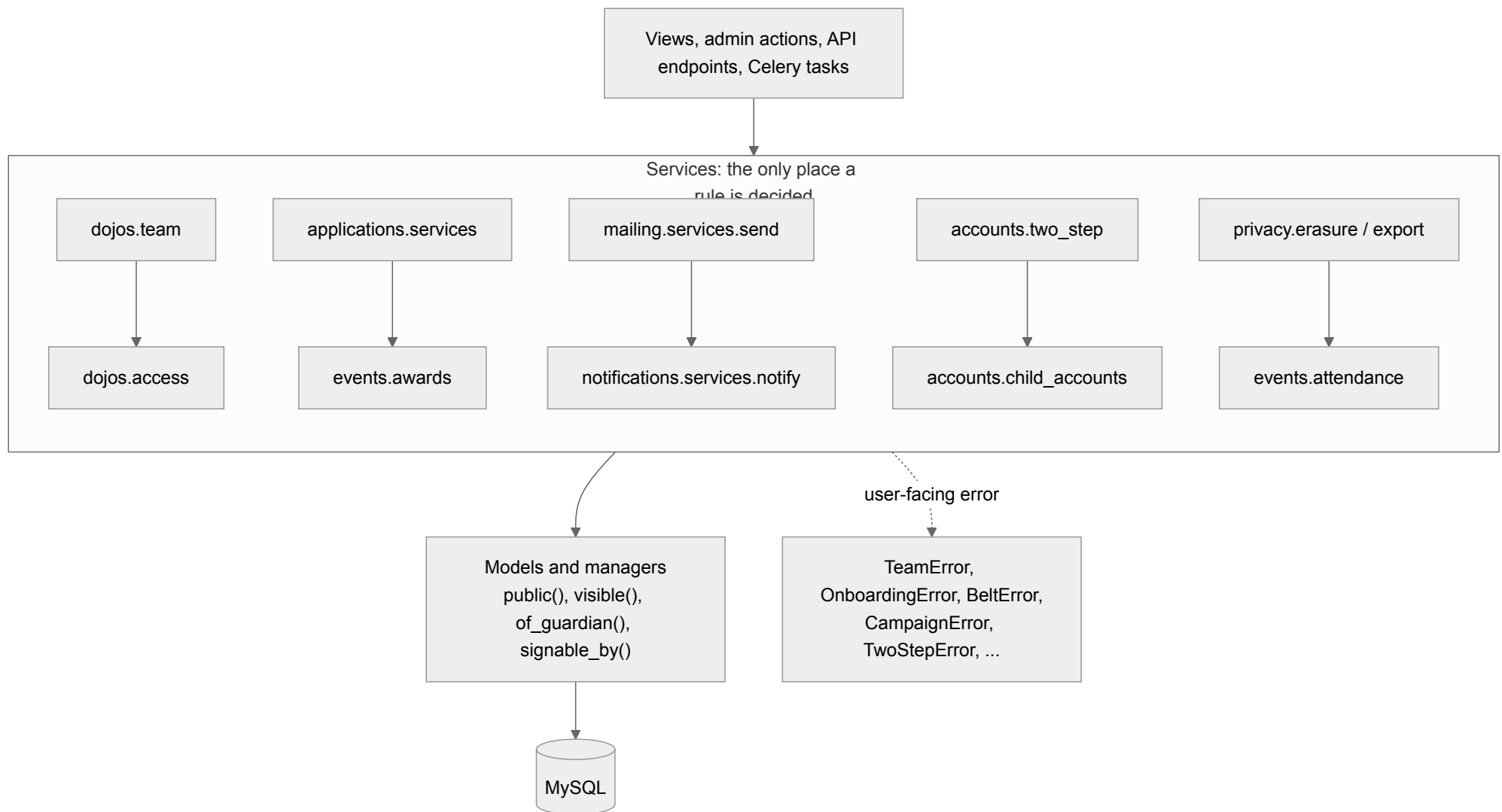
gunicorn, restart the Celery units and smoke-test. `--check` is a read-only preflight.

- No CI: tests and lint (`ruff`) run locally, inside the container.

3 Architectural principles and their rationale

A handful of rules shape almost every part of the code. Each one exists because the alternative went wrong, or would have, for a site that holds children's data and is maintained by volunteers.

Rules live in services, views only call them



Every change with a rule behind it goes through one module, which raises an error with a user-facing message.

Why. One place decides each rule, so a view, an admin action, the API and a Celery job can never disagree. The API's attendance endpoints call the same `events.attendance` functions as the dojo's attendance list.

404, not 403, for what you may not see

A dojo you are not on the team of, a child you are not a guardian of, an organisation page your role doesn't open: all answer 404. A 403 is only for someone who *is* on the team but whose role lacks the capability.

Why. A 403 confirms the thing exists. Guessable ids must not reveal which dojos, children or accounts are there.

Keep the history, never overwrite it

- Team memberships go `dormant`, never deleted, so past sessions keep their team.
- Belts (`NinjaBelt`), background-check decisions, consent (`ConsentEvent`) and cancellations (`RegistrationCancellation`) are append-only logs.
- A campaign freezes its segment at launch; a mail row stores exactly what was sent.

Why. Insurance, disputes and GDPR accountability all need to know what was true *then*, not what is true now.

Delete what you must not keep

A criminal-record extract is deleted the moment a reviewer decides; only the decision stays. Private files have no URL at all (`private_storage`, `base_url=None`), only a permission-checked download view.

The Django admin always works

Day-to-day work gets a page in a dashboard (the dojo area or the organisation area). The admin stays fully usable for every model, never read-only, never with hidden fields, so that direct database access is never needed; a test checks that a superuser can add, change and delete every registered model. The one exception is the audit log. Access to the admin itself is time-boxed: an organisation role asks for it, 12 hours at a time.

Server-driven UI

htmx for anything that needs the server, plain HTML/CSS for pure client behaviour, hand-written JavaScript only for what neither can do (passkeys, geolocation, scroll). Third-party browser code (htmx, OpenLayers, fonts) is served from our own static files, never a CDN, so visitors' IP addresses don't go to a third party.

Correctness traps turned into rules

- **Distances** always use `geo.functions.DistanceSphere` (MySQL `ST_Distance_Sphere`): Django's `Distance()` silently returns planar degrees on MySQL.
- **A model's `__str__` never queries:** under ASGI a lazy lookup raises `SynchronousOnlyOperation`; managers preload what `__str__` needs.
- **Public caches are cleared on save** by signals, so a published session shows at once.

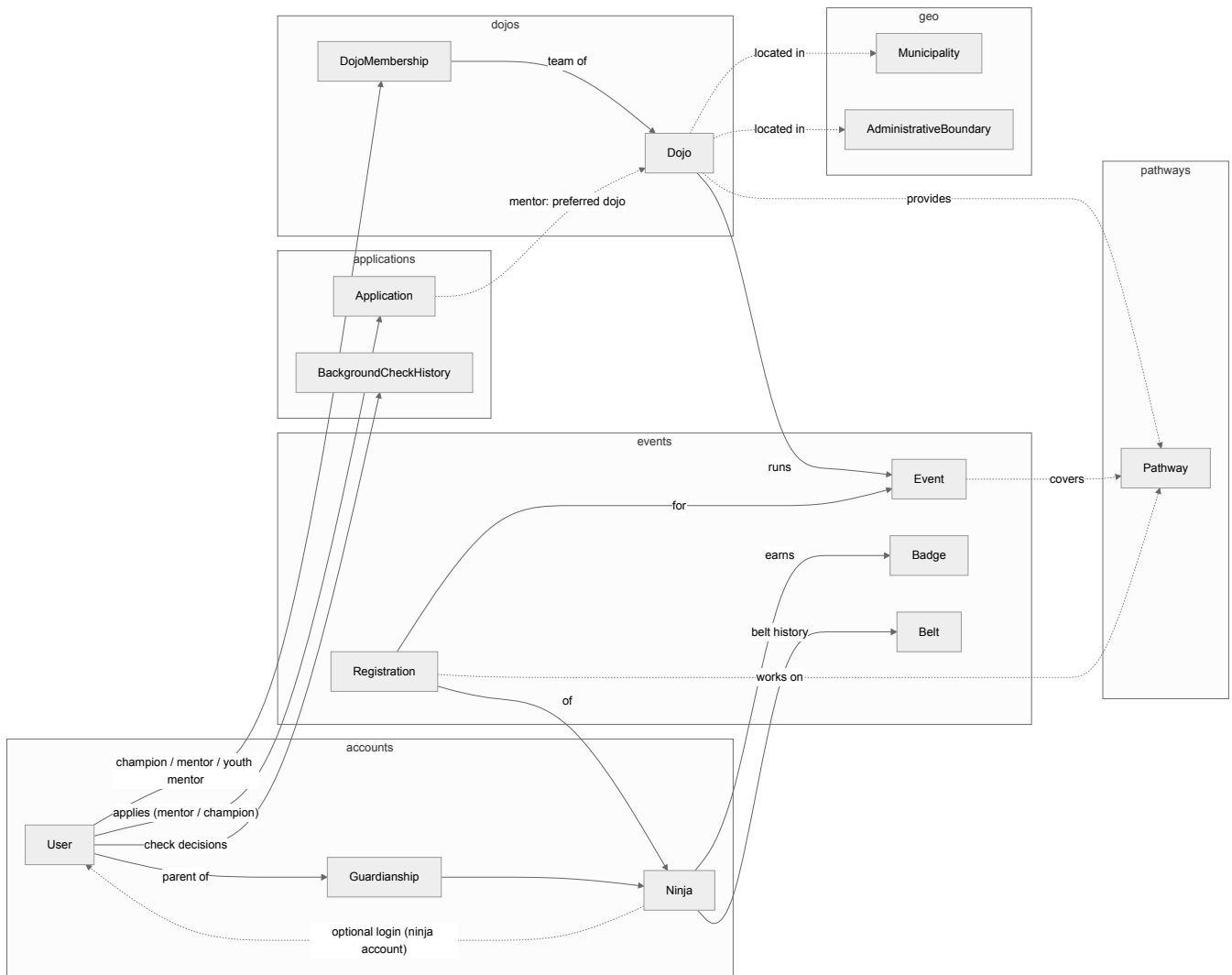
- **Tasks are safe to run twice** (`acks_late` , idempotency keys): a worker that dies mid-task is retried.

Enforced by tests

Many of these are guarded by tests that fail on a new model or field that forgets them: every field has a privacy classification, every model has an audit-log decision, every registered model is fully usable in the admin, every `__str__` that follows a relation is preloaded, every form text is translated, the API schema never exposes a sensitive field, and no page loads a script from another site.

4 The data model at a glance

Twelve apps own the data, each with its own `urls.py` mounted at the top level. The diagram shows the main entities and how they connect.



The main entities, grouped by the app that owns them (DATA_MODEL.md §1).

App	Owns
accounts	User (every login), Ninja , Guardianship , organisation roles, admin-access grants, invitations, the sign-in policy
dojos	Dojo (with its lifecycle), DojoMembership (the team), access rules, geo-search
events	Event , Registration , cancellations, badges, belts, team attendance, the engagement snapshot
applications	Application , BackgroundCheckHistory , the background-check flow
pathways	The learning-track catalogue: pathways, steps, projects, skills
content	FAQs, testimonials, announcements, promotions, sponsors, the organisation's team listing
notifications	Per-recipient Notification rows behind the bells
mailing	Every mail: queue, templates, preferences and consent, bounces, campaigns, segments, journeys
geo	Municipalities and administrative boundaries, geocoding, DistanceSphere
privacy	The GDPR registry, export, erasure, retention, erasure records
api	A dojo's API clients and the /api/v1/ endpoints
core	The homepage, shared templates and static files, the management shell, audit-log wiring

Nomenclature

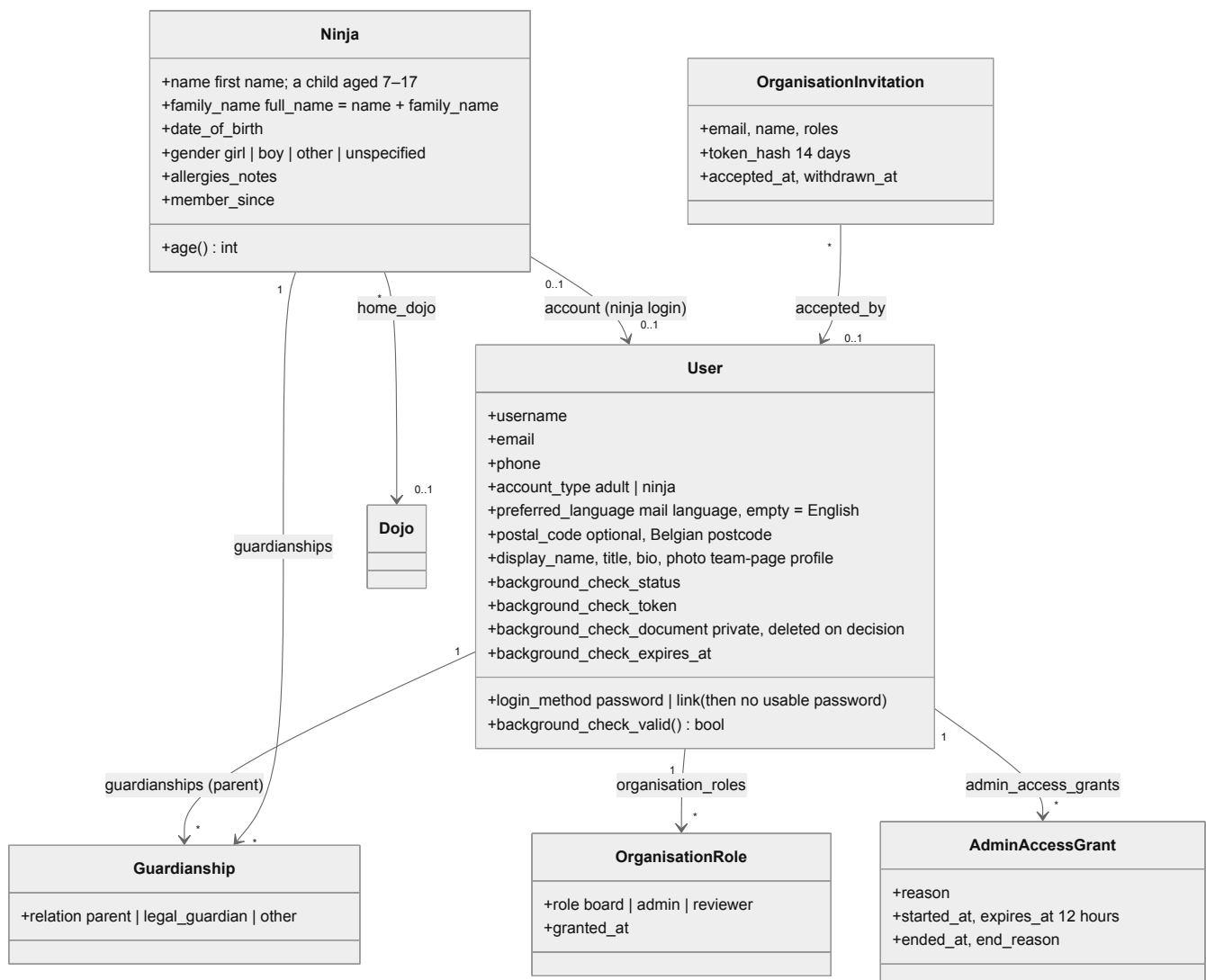
The code and the UI use CoderDojo's own vocabulary:

Term	Meaning	In the model
Champion	The dojo owner; exactly one per dojo	membership role champion
Mentor / Coach	An adult helper	membership role mentor
Ninja	A child aged 7–17 visiting a dojo	Ninja , plus an optional ninja login (User)
Youth mentor	A ninja helping run sessions	membership role youth_mentor on a ninja login
Badge	An award: one-off, or a milestone reached by a count	Badge (one_off / milestone), NinjaBadge
Belt	A ninja's proficiency level	Belt , the append-only NinjaBelt history

5 Accounts, families and roles

One `User` table is every login, told apart by `account_type`: `adult`, `ninja` (a child's own login) or `service` (an API client's technical account). There are no role subclasses.

- **Parents** are plain adult accounts linked to children through `Guardianship` (a child can have several guardians). No check, no approval: a parent only ever manages their own children.
- **A Ninja is not a user.** It gets a login only if a guardian gives it one; most never do. The guardian creates and removes it and keeps editing the child's details.
- **Champions and mentors** are adult accounts with an approved `Application` and a valid background check; what they do at a dojo is a `DojoMembership`.
- **Organisation roles** (`board`, `admin`, `reviewer`) map to permission groups kept in sync by signals, and open areas of the organisation dashboard. The Django admin needs a separate, 12-hour grant.
- Every login chooses a **password or an emailed login link**, with optional two-step login on top.

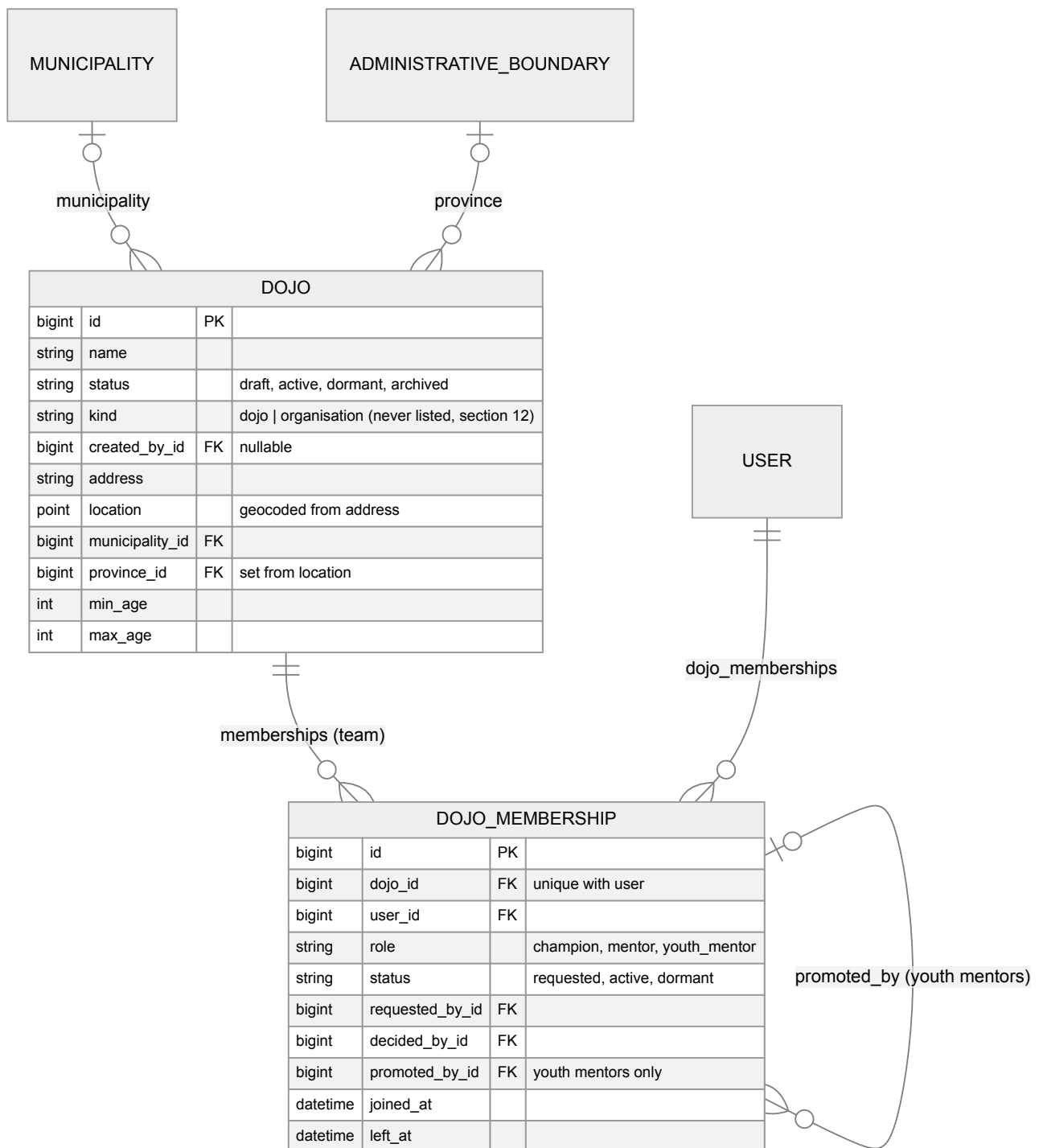


Accounts, guardianship and organisation access (DATA_MODEL.md §2).

Why. Being a parent, a mentor or a champion describes how a person relates to children or to a dojo, not what kind of account they have, and one person can be all three. Modelling roles as subclasses spread one idea over several tables and needed sync code; relations make each role a row that can be added, ended and audited.

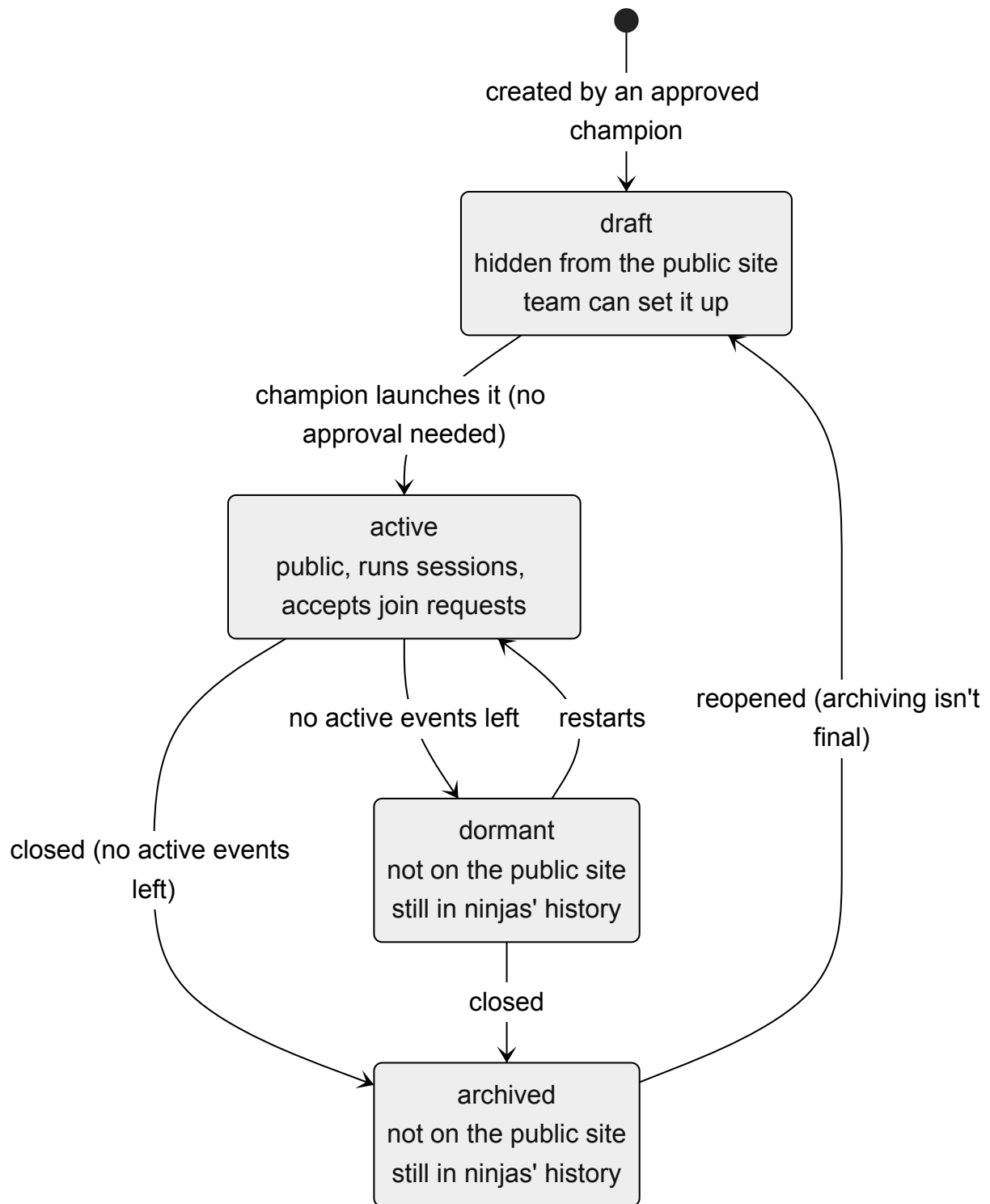
6 Dojos, teams and access

A dojo's team is a set of **memberships**, one row per account and dojo, each with a role and a status. The team-page profile (name, title, bio, photo) lives on the account and is shared by every dojo.

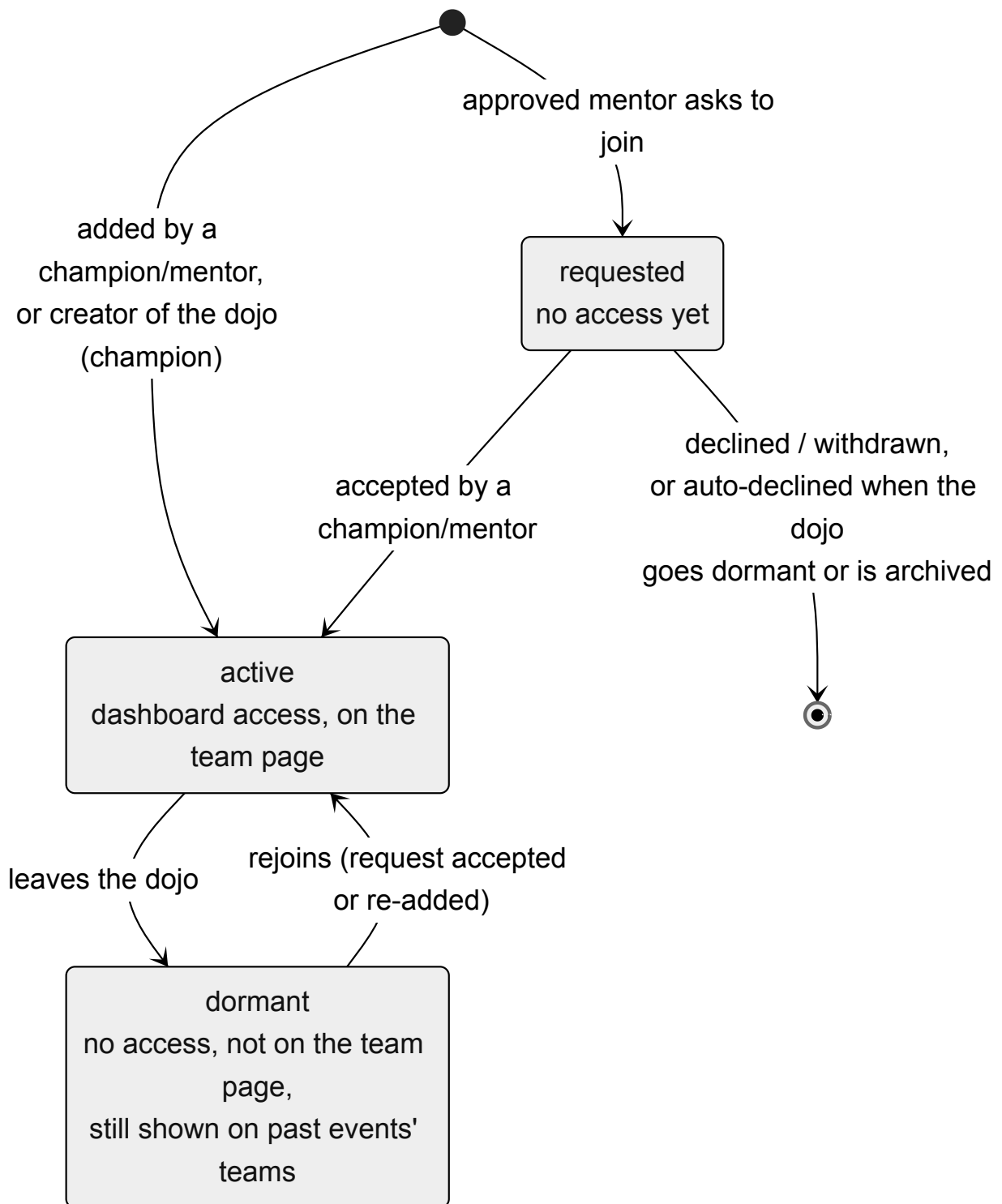


Dojos and their team memberships (DATA_MODEL.md §3).

Lifecycles

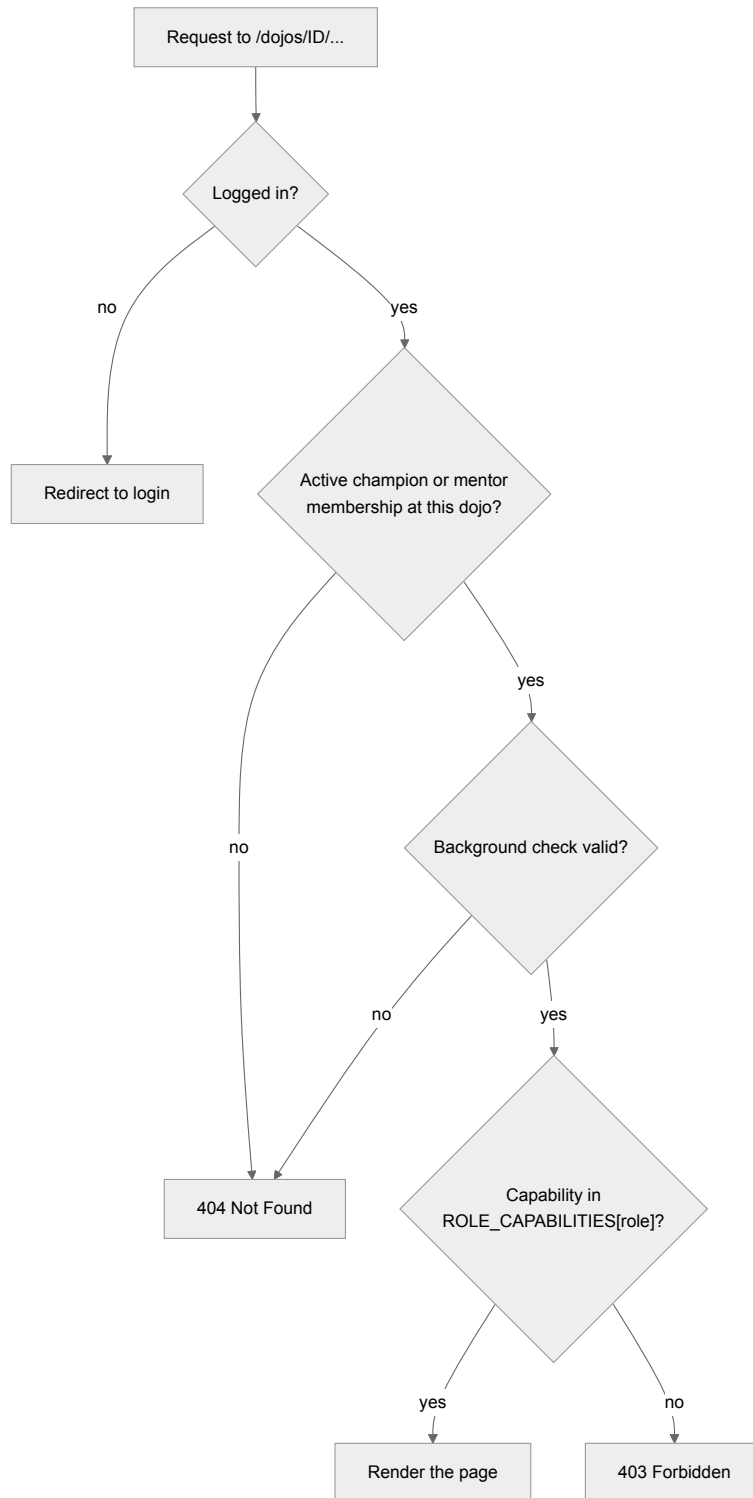


A dojo's status. Only active dojos (and their sessions) are public. Going dormant or archived needs no open sessions and declines pending join requests.



A team membership. Leaving makes it dormant, never deleted, so past sessions keep their team.

Who gets into a dojo's admin area



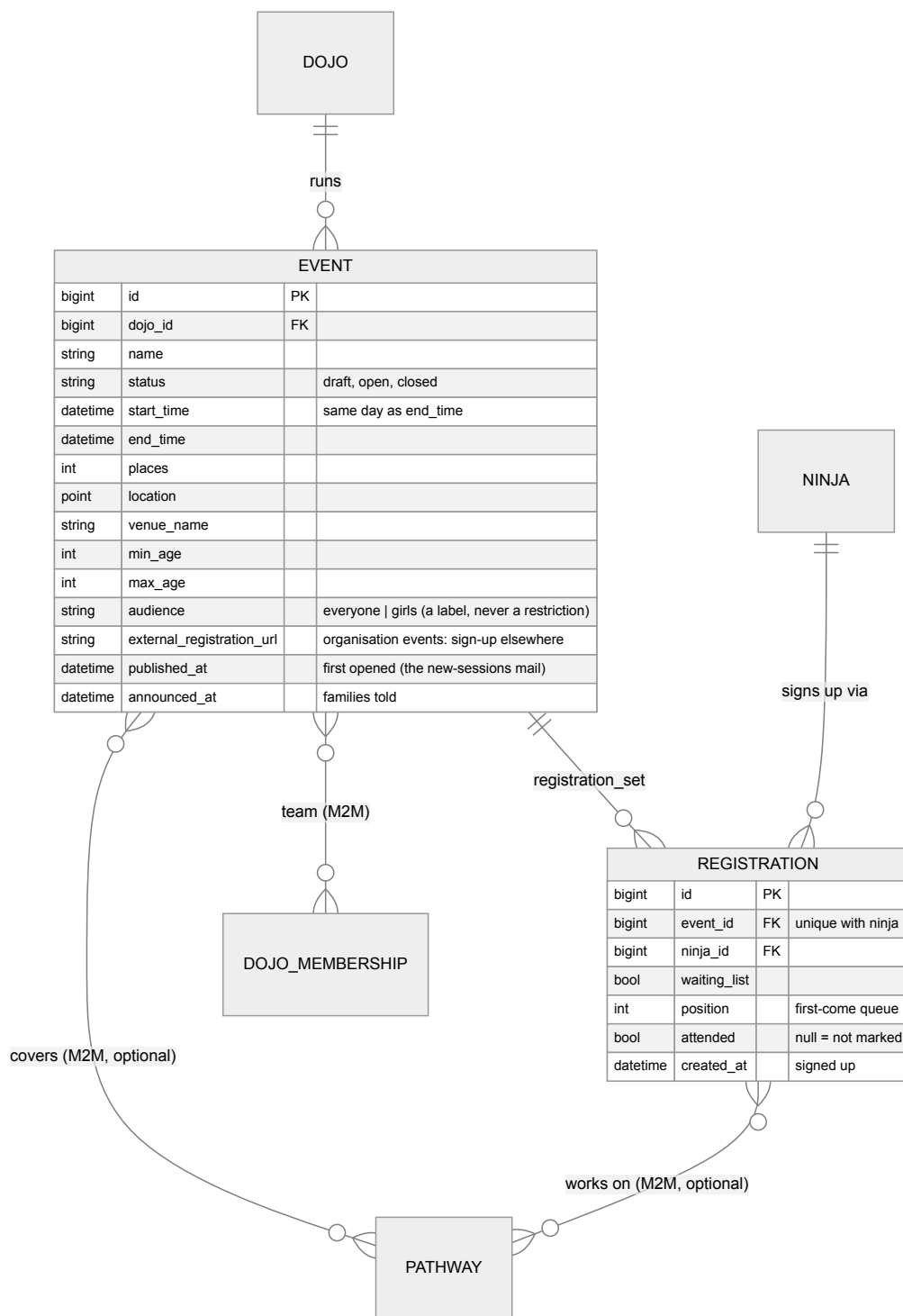
Access is always resolved through `dojos.access.require_dojos_access`.

Capability	Champion	Mentor
Dashboard, sessions list, the bell (any role)	✓	✓
TAKE_ATTENDANCE , MANAGE_EVENTS , EDIT_SETTINGS , MANAGE_TEAM	✓	✓
AWARD_BELTS , AWARD_BADGES , POST_UPDATES	✓	✓
MANAGE_LIFECYCLE , VIEW_HEALTH_NOTES , MANAGE_API , SEND_MAIL	✓	—
Hand over the champion role	✓	—

Why. A lapsed background check never blocks login: the person can still use the site as a parent, but their memberships stop granting access until a renewal is validated. The membership keeps its status, so nothing needs repairing afterwards.

Organisation-run events (CoderDojo Girlz, Coolest Projects) live on an **organisation dojo** (`Dojo.kind = organisation`): a normal dojo with a team and an admin area, never listed publicly, and the only kind whose events may link out to an external registration site.

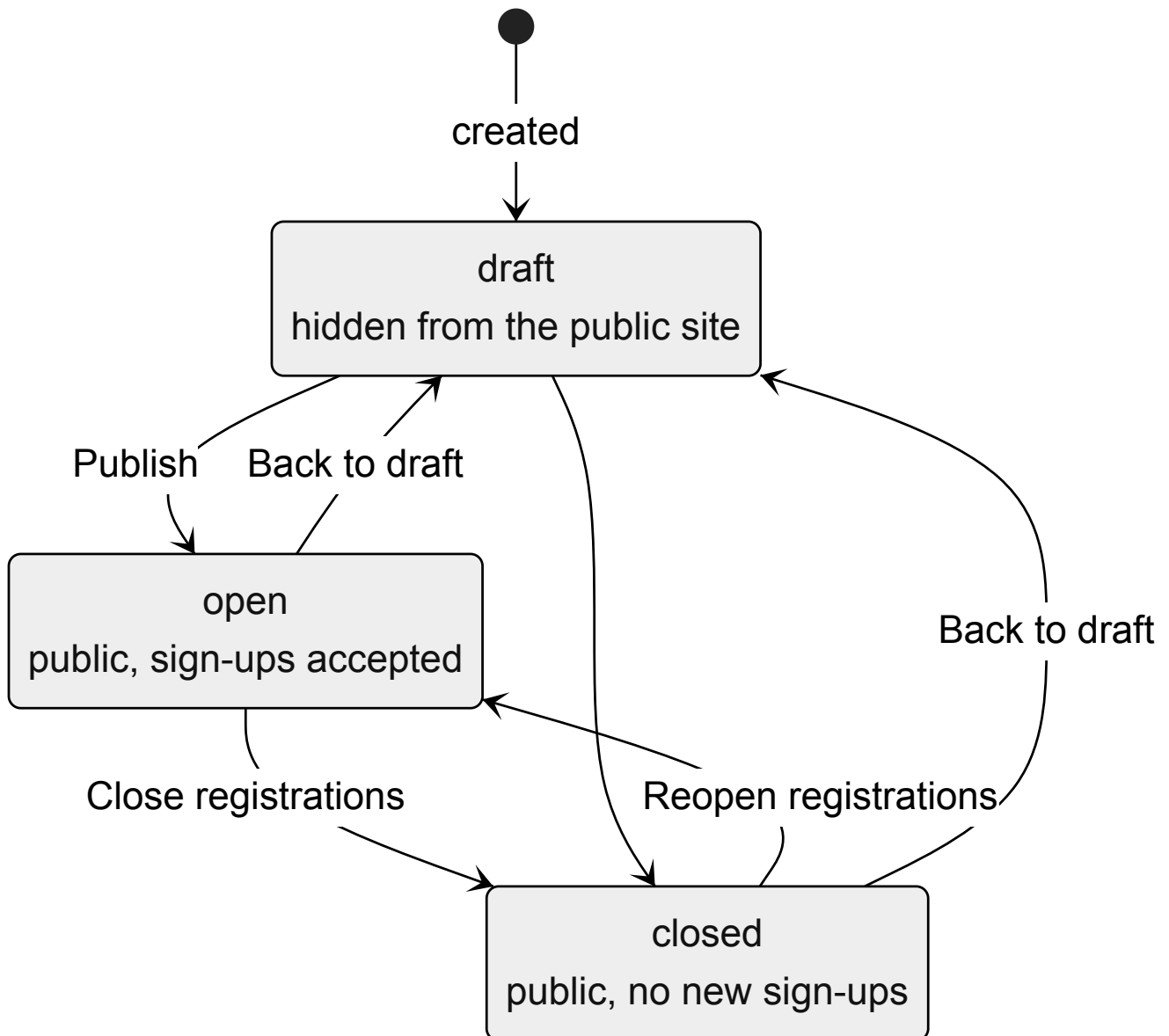
7 Sessions, registrations and attendance



Events, registrations, pathways and the session's team (DATA_MODEL.md §4).

- **Places and the waiting list.** Places left = places – confirmed registrations. Cancelling deletes the registration (after logging a `RegistrationCancellation`) and promotes the first child waiting; that family is mailed and the dojo's team notified.
- **Attendance is tri-state** (`None` = not marked, present, absent), for children and for the session's team (`TeamAttendance`, the record the insurance needs).
- **A girls' session** (`Event.audience`) is a label and a targeting signal, never a sign-up restriction.

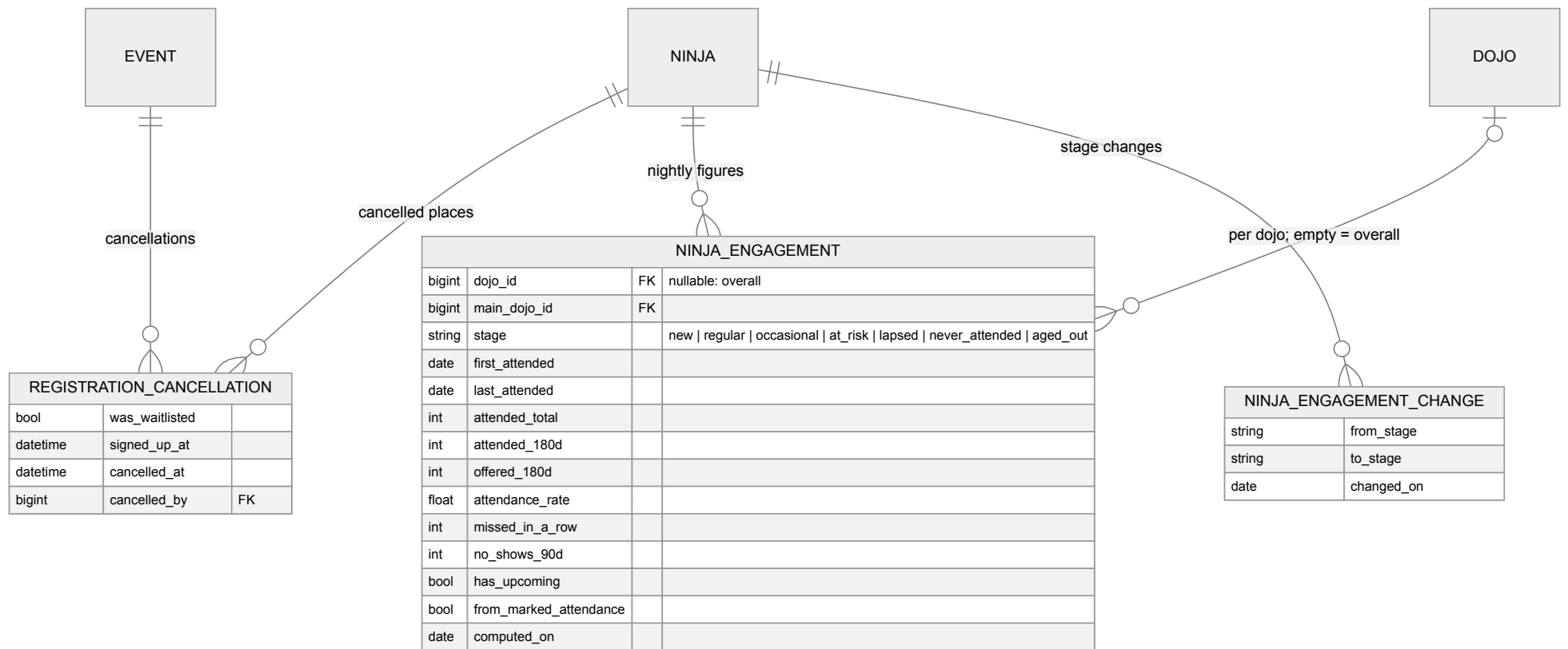
- **Home dojo:** set at a child's first sign-up, then only the guardian changes it.



A session's status is set directly by the team; it isn't one-way, and registrations are always kept.

Engagement

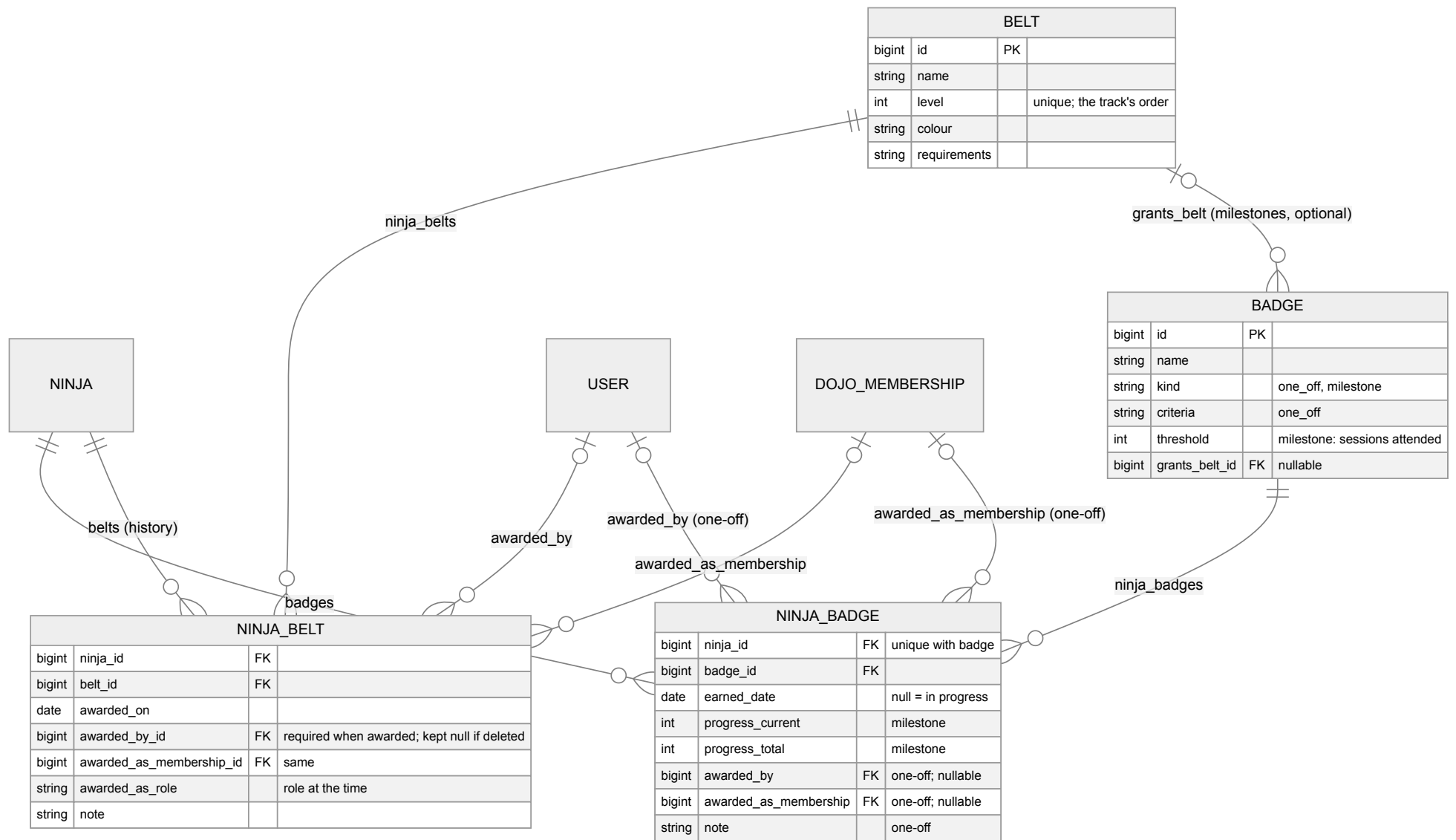
Every night `events.engagement.rebuild()` recomputes, per child and dojo, how they come to sessions: new, regular, occasional, at risk, lapsed, never came or aged out. Only sessions meant for the child count (age range, girls' sessions for girls). Stage changes are logged, which lets a *journey* send a "we miss you" mail the week a child becomes at risk.



Cancellations and the nightly engagement snapshot.

8 Badges and belts

- A **badge** is an award. *One-off* badges are awarded by a dojo's team from the attendance list; *milestone* badges (the attendance wristbands) are recomputed whenever attendance is marked and stay earned. Only the organisation defines badges.
- A **belt** is a ninja's proficiency level on one track, the only record of their coding level. The history is append-only; the current belt is the highest. Only an active champion or mentor awards one, recording the account *and* the membership ("Jan, as mentor of Dojo Ghent"). A milestone badge can grant a belt.



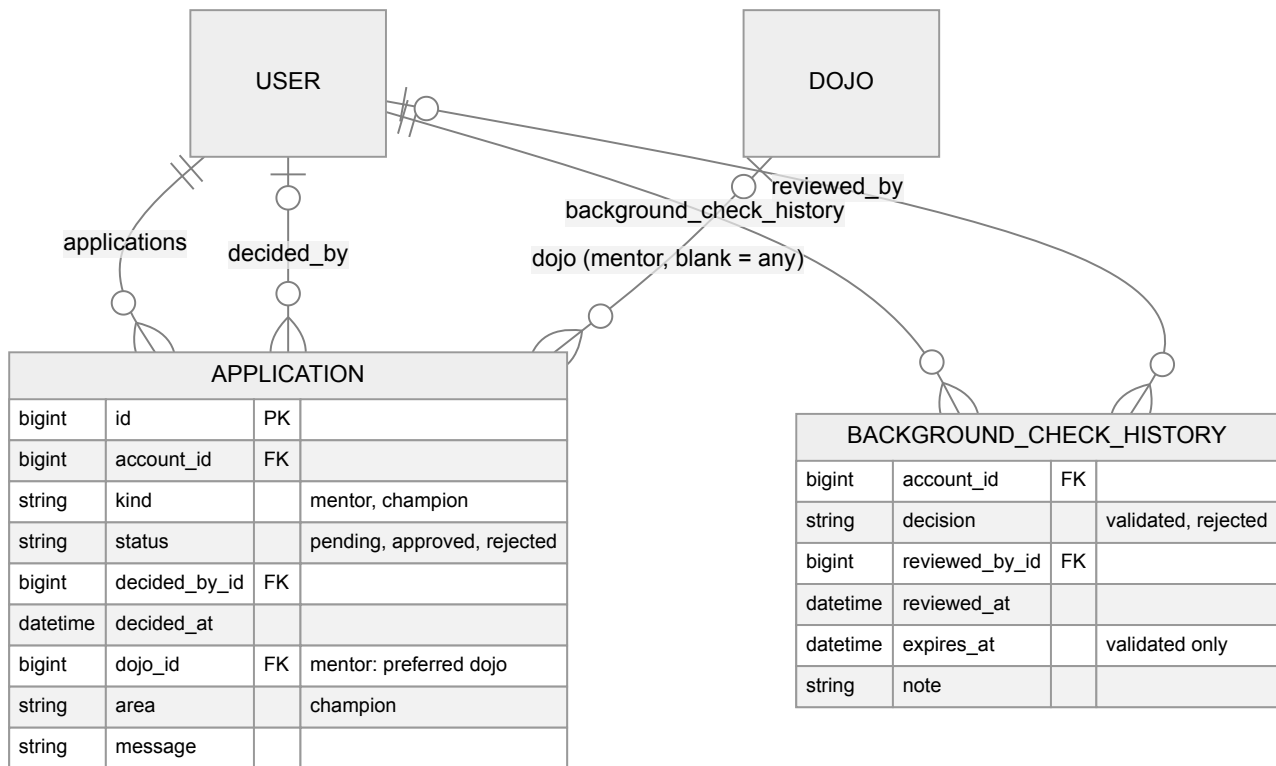
Badges and belts; all rules in events/awards.py (DATA_MODEL.md §5).

Why. Attendance and skill are different things: a child who comes every week isn't necessarily an advanced coder. Keeping milestones as badges and belts as a separate level lets both be shown honestly.

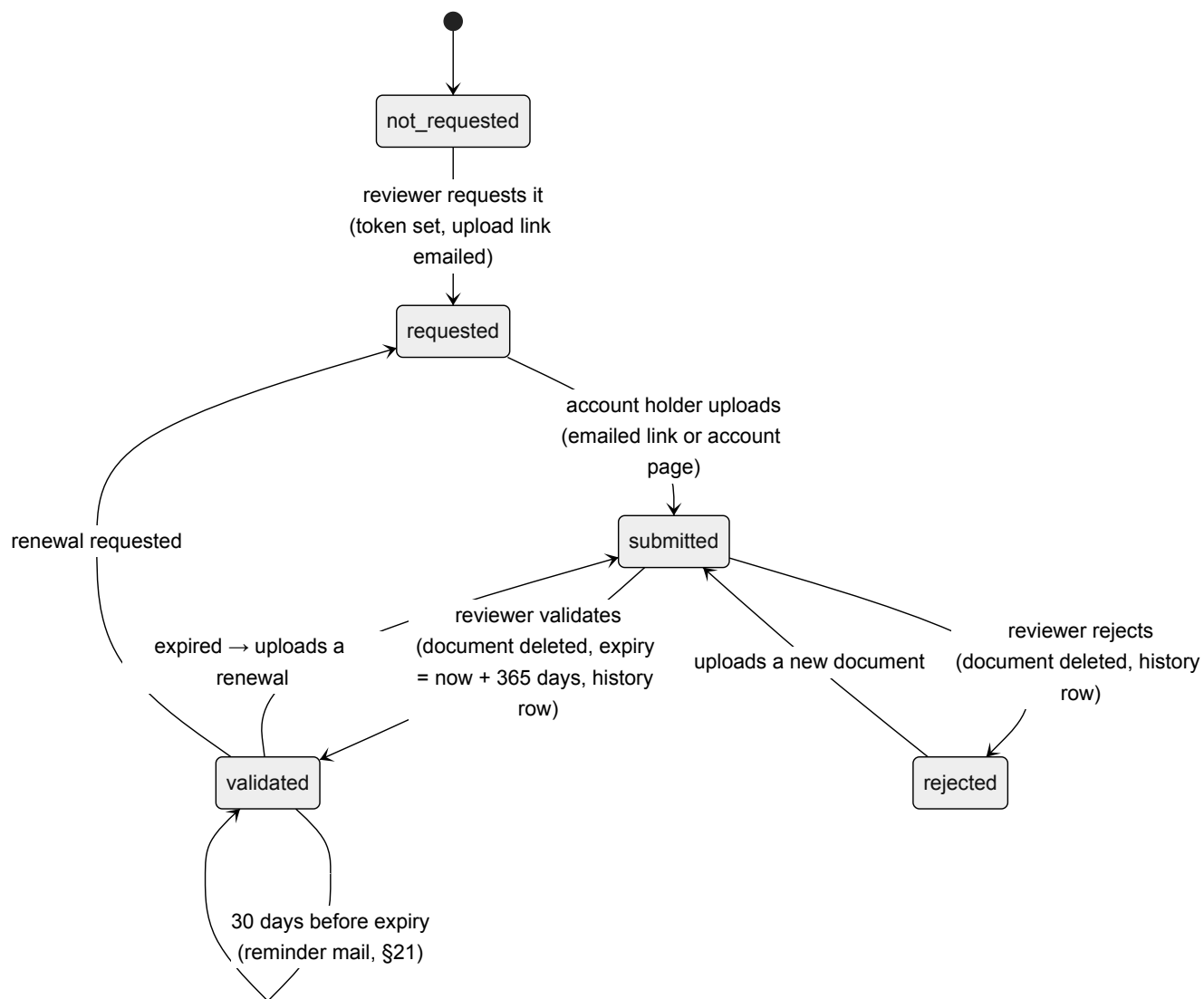
9 Volunteers: applications and background checks

Belgian law (Art. 596.2) requires a criminal-record extract, model 2, for anyone working with minors.

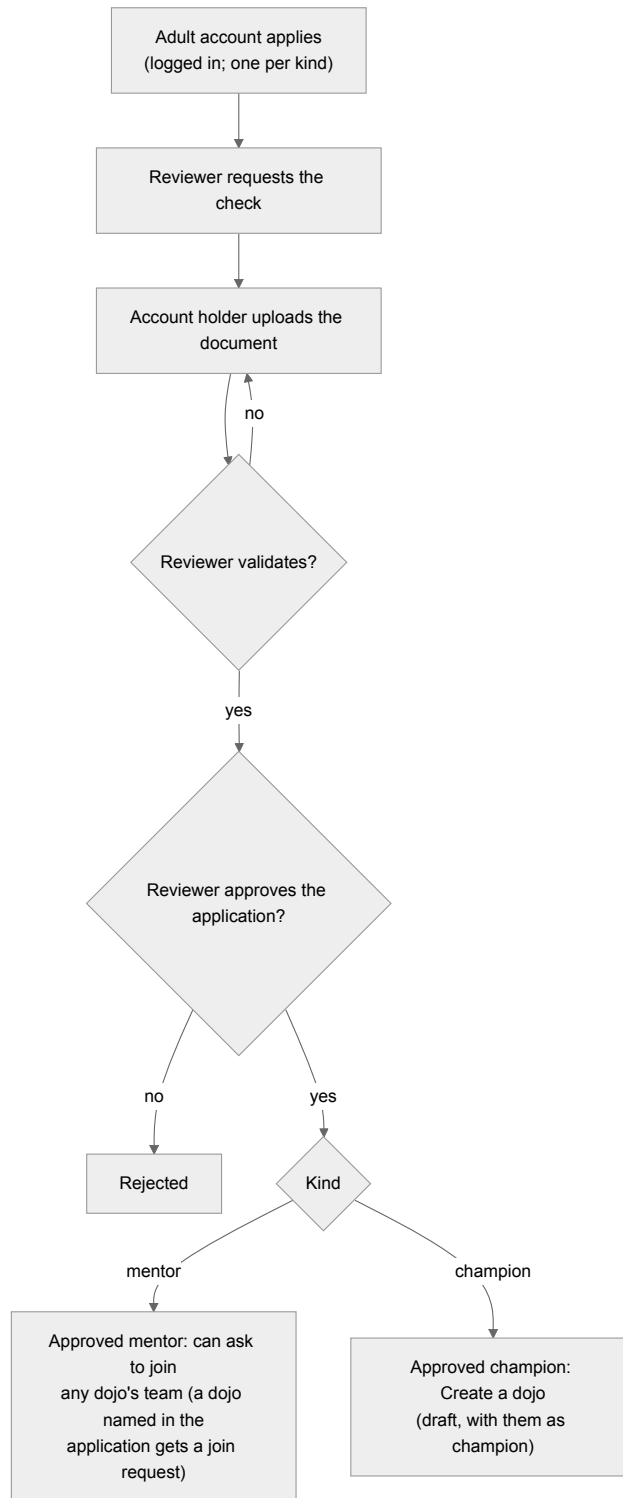
Onboarding is **per account, once**: an approved mentor can join any number of dojos, an approved champion can create one.



Applications and the append-only decision history (DATA_MODEL.md §6).



The background check lives on the account. Either decision deletes the document.



From application to a dojo.

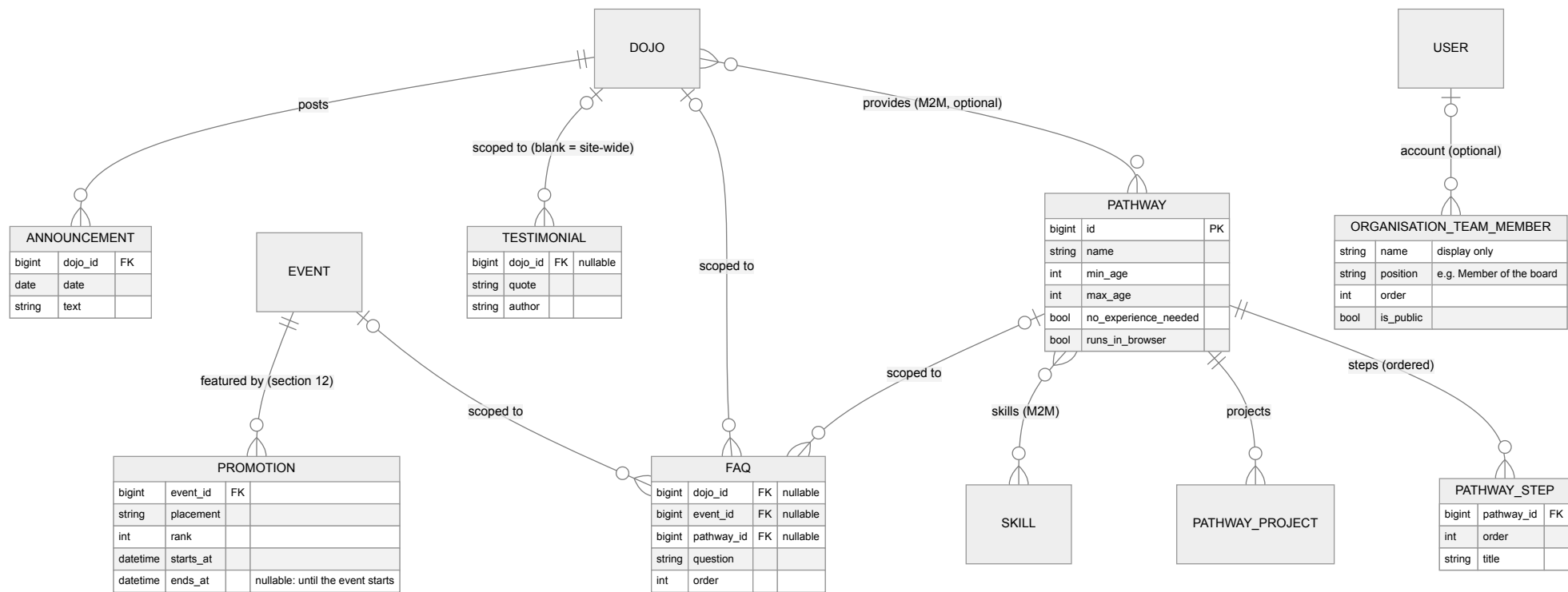
Why. A check is about a person, not about a dojo. Per-dojo applications made volunteers repeat the process and scattered the check across rows. Keeping only the decision (who, when, until when) and deleting the extract itself keeps the most sensitive document the site ever sees for the shortest possible time.

Reviewers work on the organisation dashboard's *Volunteers* pages; nobody decides on their own check or application. The account holder is reminded 30 days before expiry, and reviewers get a daily mail while documents wait.

10 Pathways, content, notifications and geography

Pathways and content

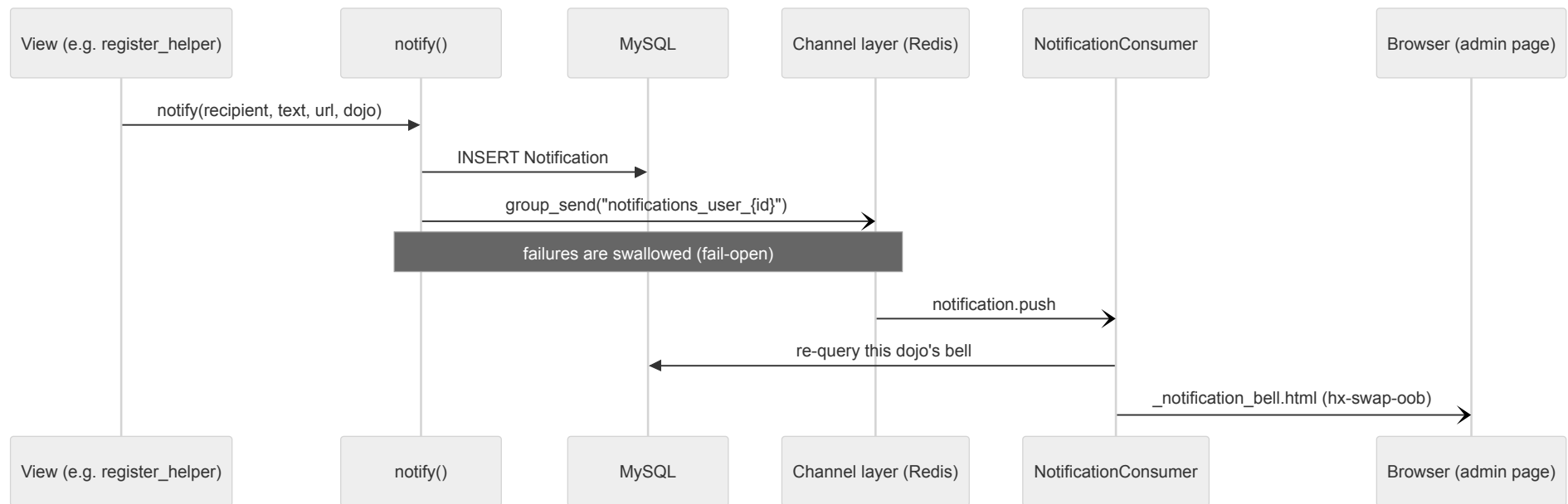
Pathways are a read-mostly catalogue, linked at three optional levels, each pre-filled from the one above but never restricted to it: what a dojo provides → what a session covers → what one ninja works on.



Pathways and the content models; content is scoped to a dojo, event or pathway, or site-wide (DATA_MODEL.md §7).

Notifications

One row per recipient, so read state is per person. `notify()` writes the row (the source of truth), then nudges the recipient's open pages over the Channels layer; a failure there is swallowed. Texts are stored as translatable messages and rendered in the *recipient's* language.



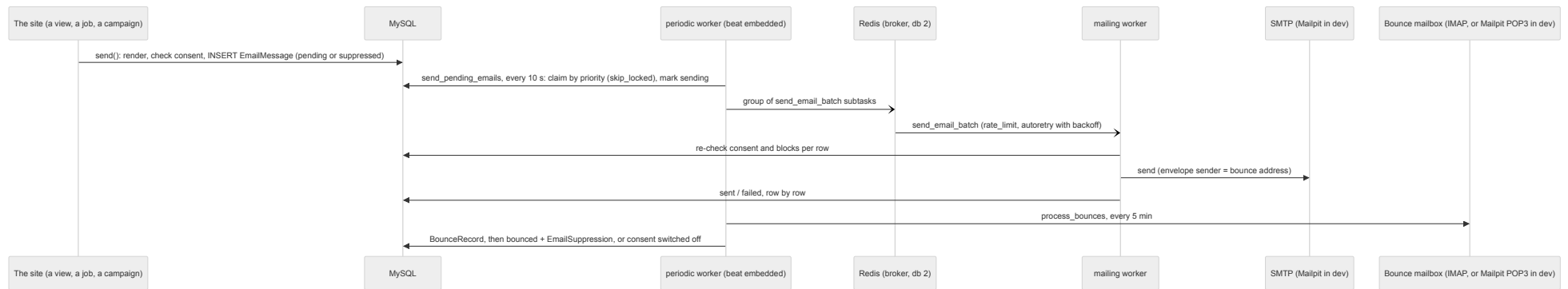
A live notification: the consumer re-renders the bell and htmx swaps it in.

Geography

Municipalities (postcodes with a centre) and administrative boundaries are reference data. A dojo's province is derived from its geocoded location (point in polygon, nearest boundary as fallback). The dojo finder orders by `DistanceSphere` from a typed address, the browser's location, the family's postcode or a Ghent default; only the default list is cached, so one family's results never leak to another visitor.

11 The mail engine

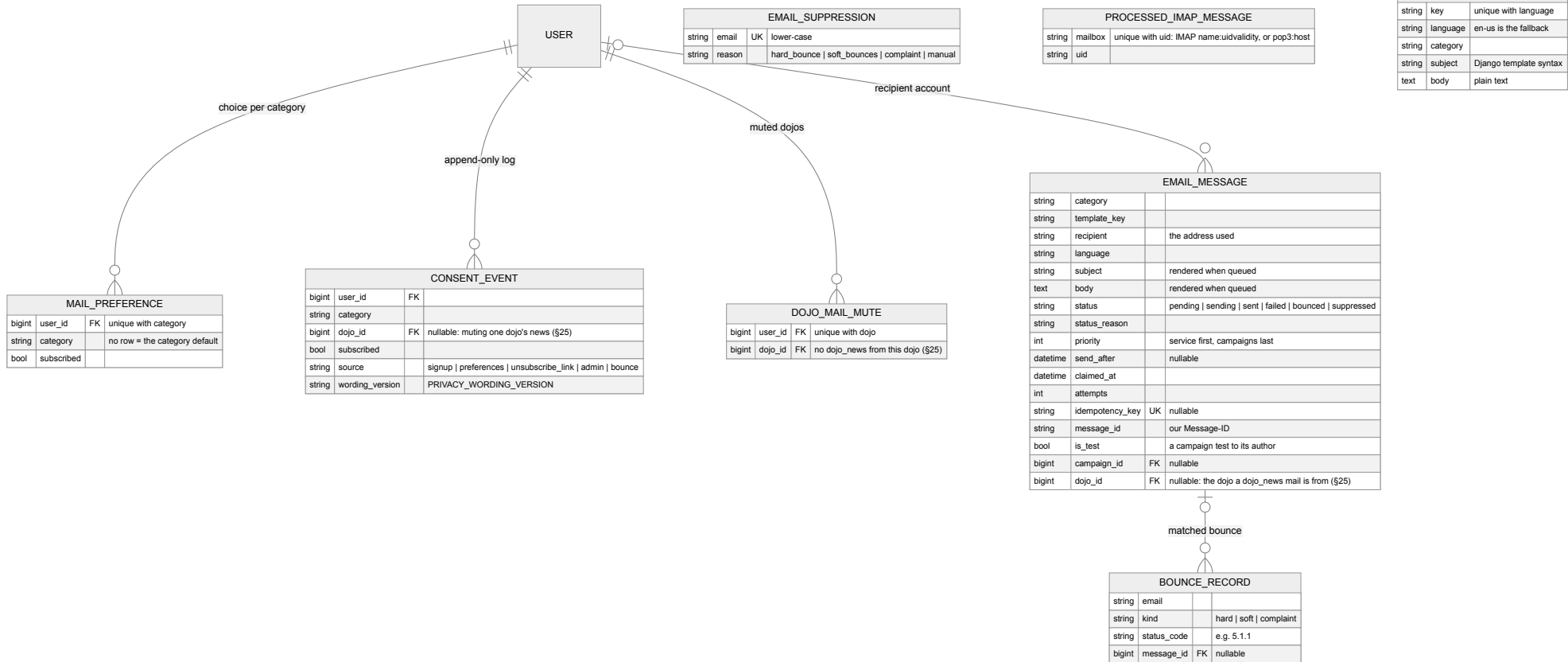
Every mail goes through one gateway, `mailing.services.send()` : it renders the template in the recipient's language, checks consent and blocks, and inserts an `EmailMessage` row. **The database is the queue**; the Celery workers only send.



How a mail goes out (DATA_MODEL.md §11).

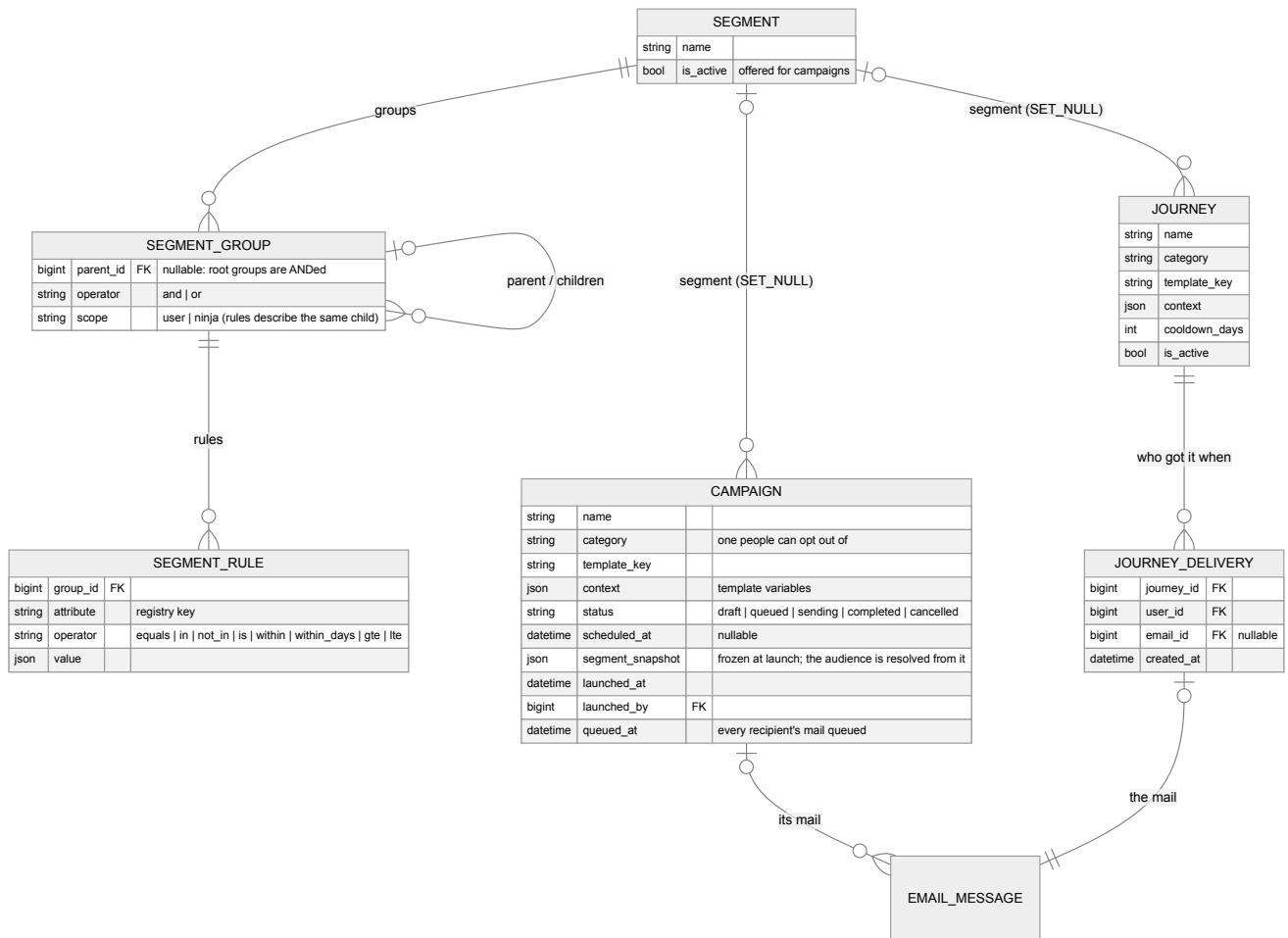
Why. A row per mail is the record of exactly what was sent, survives a broker restart, and makes retries and idempotency simple: a row is marked sent right after its own send, so a retry never mails anyone twice.

Worker	Runs	Why separate
<code>periodic</code> (beat embedded)	The 10-second dispatcher, requeueing, bounces, the jobs beat triggers	The dispatcher never waits behind a big campaign; exactly one beat.
<code>mailing</code> (default queue)	Batches of mail, campaign launches, everything else	With one process, Celery's rate limit is the real limit towards SMTP.



Consent and preferences, the queue, blocks and bounces.

- **Categories** (service, registration, reminder, dojo news, volunteer, newsletter) each with a default and whether people may opt out; `ConsentEvent` logs every change with the privacy wording's version.
- **Segments** describe an audience without code: nested groups of rules about accounts or about “the same child”; each rule is its own subquery. Child rules only reach guardians who consented.
- **Campaigns** freeze their segment at launch; **journeys** are standing campaigns run daily with a cool-down.
- **Bounces** are read from a mailbox (DSN, ARF): a hard bounce blocks the address, a complaint switches off optional mail.
- **A dojo's own mail** is a campaign with a dojo, sent by its champion to prepared audiences, with Reply-To the dojo.

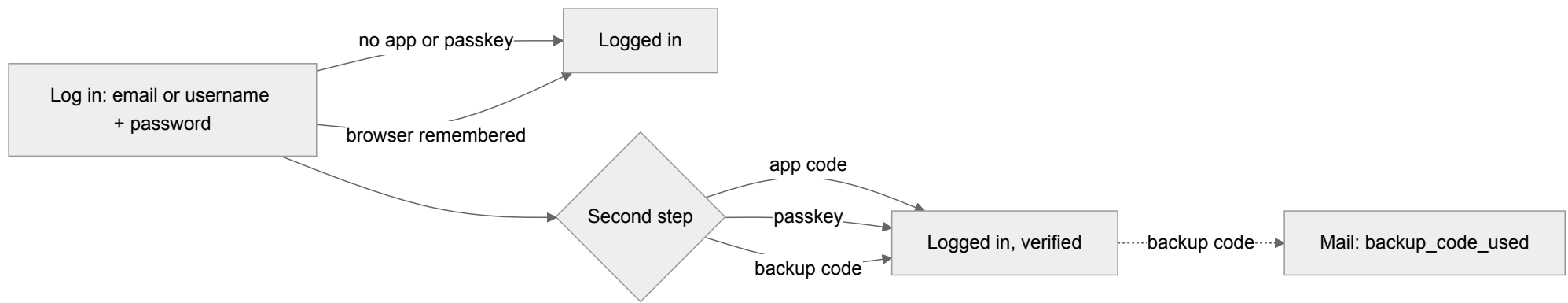


Campaigns, journeys and segments.

12 Security

Logging in

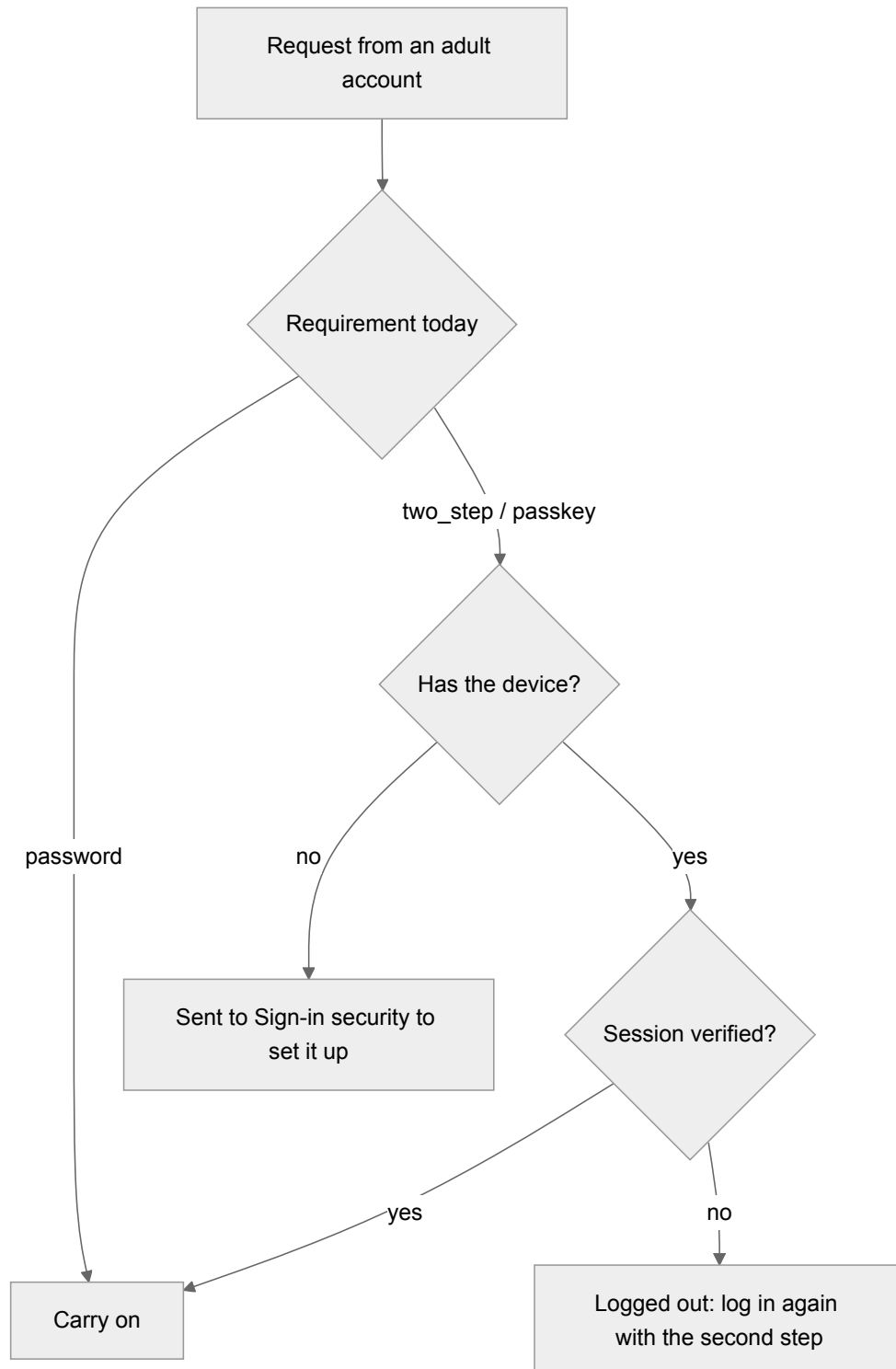
There is one login page. A login link is the same login view with a different first step, so the second step always follows. Passkeys are checked against the site's own URL, since TLS ends at the proxy.



Password (or login link), then the second step when the account has one (DATA_MODEL.md §15).

The sign-in policy

The organisation sets, per role and from a chosen date, the minimum: password, two-step login or passkey. An account's requirement is the strongest among its roles. Today every role is on "password"; the enforcement is in place for when that changes.



Enforcement: a middleware guides, and every door a role opens checks again.

Access to the management side

- The organisation dashboard is split into **areas** (communication, public site, ninjas, privacy, security, volunteers, audit log), each opened by a permission the roles grant.
- The **Django admin** needs a grant asked for with a reason and the password, for 12 hours; the other admins are notified. Superusers are only made on the server.
- The **API** gives an app one dojo's data with scoped OAuth 2.0 tokens, through its own technical account, and is tested never to expose a field classified as special, criminal or security data.

13 Privacy by design

Most of the data is about **children**, one field is **health data** (allergies and notes, GDPR art. 9) and one flow handles **criminal-record extracts** (art. 10). Privacy is therefore built into the model rather than bolted on.

Every field is classified

Each app declares its models in a `privacy.py` : purpose, legal basis, retention, who sees it, and for every field whether it is personal (and in which category) and what happens to it on erasure: emptied, anonymised with a replacement, or kept with a reason. A test fails on any unclassified field, ours or third-party. From that one registry:

- **The register of processing activities** (`manage.py privacy_register`).
- **A person's export** (art. 15/20), for families from their account page and for the organisation on request.
- **Erasure**: rows are found by the registry's subjects, fields emptied or anonymised, `User` and `Ninja` rows anonymised, never deleted, and an `ErasureRecord` without personal data allows replaying erasures after a backup restore.
- **Retention**: an account is erased two years after its last login, after reminder mails; champions and mentors keep their public team profile.

The audit log

django-auditlog records changes to the models listed in `core.audit.RECORDED` (every other model has a written reason why not) and views of special-category data. Health notes and secrets are masked; IP addresses are never stored. It is read-only, for the organisation's admins, and its entries follow the same retention and erasure.

Who sees the most sensitive data

Data	Seen by	Safeguard
A child's health notes	The dojo's champion, only for children with a confirmed place	Every view recorded in the audit log
Criminal-record extract	Reviewers, until they decide	No URL; deleted on decision; downloads recorded
Families' addresses	Never the dojo team	Dojo mail shows counts only

14 Languages, testing and operations

Three languages, two kinds of text

- **The site's own texts** (templates, forms, messages, `bundle.js`) are in gettext catalogs for Dutch and French; Dutch uses the informal “je”, French “vous”. The site language follows a cookie; an account's `preferred_language` is only its mail language.
- **Content** written by people (a dojo's description, session names, updates, the organisation's pathways and badges) is stored per language on the row, in the languages the dojo (or the organisation) chose; visitors see the main language with an “Only in ...” note when theirs is missing.
- Mail templates are rows per language, falling back to English.

Testing

- About 1,000 tests with the plain Django runner, inside the devcontainer, on their own Redis cache database.
- Route tests check status codes, templates, permission gating (404 versus 403) and the database effect of a POST.
- Channels consumers are tested with `TransactionTestCase` and an in-memory layer; Celery tasks by calling the function, never `.delay()`.
- The guard tests of chapter 3 keep new code honest about privacy, auditing, the admin, translations and the API schema.

Operations

- One deploy script, with a preflight and a `manage.py check` before the live app is touched.
- Mail waits safely in the database when the workers are down; the dashboard's mail queue warns when due mail has waited over 30 minutes.
- Seed commands build a realistic demo world (dojos, families, volunteers, histories, waiting lists) and a credentials file describing what each login can do; the user-journey PDFs are made from it.

Known gaps and open points

- The full mail log, retrying a failed mail and lifting a block are only in the Django admin.
- The API covers dojo clients and attendance; external registrations and event management are planned (§13).
- Some privacy retention rules wait for their periods to be decided (§16).
- Production still lacks MySQL client headers and GDAL/GEOS on the host; the deploy script refuses to go live until then.